

NETC 280 – Lab 4 – Applying NIST CSF 2.0

Instructor: Phillip Haller SP/26

Note: For this lab, the use of AI is acceptable for summarizing resources. All answers/paragraphs written should be in your own words. Document any sources used outside of those provided.

About this lab:

In this activity you will analyze a real cybersecurity breach using the NIST Cybersecurity Framework (CSF) 2.0.

You will learn how to:

- Connect real events to CSF terminology
- Identify where organizations failed
- Understand how breaches develop over time
- Recommend actions that could have prevented the incident

You are not trying to find a technical vulnerability.

You are trying to understand organizational failures.

NIST CSF 2.0 Quick Reference

GOVERN (GV)

Leadership sets expectations, policies, and accountability.

IDENTIFY (ID)

The organization understands systems, assets, and risks.

PROTECT (PR)

Safeguards exist to prevent incidents.

DETECT (DE)

The organization discovers suspicious activity quickly.

RESPOND (RS)

The organization handles the incident appropriately.

RECOVER (RC)

Operations are restored and improvements are made.

Case Study – Equifax Breach (2017)

Background Information:

Equifax, one of the three largest credit reporting agencies in the United States, suffered a massive data breach affecting 147 million Americans—nearly half the U.S. population.

ORGANIZATION PROFILE:

- Industry: Credit Reporting / Financial Services
- Size: 11,000 employees globally
- Annual Revenue: \$3.1 billion (2017)
- Data Holdings: Credit reports, Social Security numbers, financial data for millions of Americans
- Systems: Web applications, databases, authentication systems

INCIDENT TIMELINE:

- March 7, 2017: Apache releases security patch for Struts vulnerability (CVE-2017-5638)
- March 8, 2017: DHS US-CERT issues alert about critical Struts vulnerability
- March 9, 2017: Equifax security team sent email to "appropriate teams" about vulnerability
- March 15, 2017: Equifax IT performed scans but failed to identify vulnerable systems
- May 13, 2017: Attackers exploited unpatched Struts vulnerability in dispute portal web application
- May-July 2017: Attackers exfiltrated data over 76 days, making 9,000+ queries
- July 29, 2017: Equifax discovered suspicious network traffic and breach
- July 30, 2017: Breach investigation began, systems taken offline
- September 7, 2017: Public disclosure of breach

ATTACK DETAILS:

The breach exploited CVE-2017-5638, a remote code execution vulnerability in Apache Struts 2, a popular web application framework.

Despite a patch being available, Equifax failed to apply it to their consumer dispute portal. The attackers:

1. Exploited the Struts vulnerability to gain initial access to web server
2. Found database credentials stored in plain text on compromised server
3. Used credentials to access 51 databases containing consumer information

4. Exploited expired SSL certificates that prevented inspection of encrypted traffic
5. Exfiltrated data over 76 days through normal web traffic, evading detection
6. Accessed personal information of 147 million people

CRITICAL FAILURES:

1. Patch Management: Security patch available but not applied for 4 months
2. Asset Inventory: IT scans failed to identify all systems running vulnerable Struts version
3. Database Security: Database credentials stored in plain text, not encrypted
4. Certificate Management: Expired SSL certificate on inspection device prevented monitoring of encrypted traffic
5. Network Segmentation: Attackers moved from web server to access 51 databases
6. Data Access Controls: No adequate controls on database access or data exfiltration
7. Monitoring: 76-day exfiltration period went undetected
8. Incident Response: 6-week delay between discovery and public disclosure

DATA COMPROMISED:

- 147.9 million U.S. consumers affected
- 209,000 credit card numbers
- Social Security numbers, birth dates, addresses
- Driver's license numbers for 10.9 million people
- Data considered "crown jewels"—used for identity verification by banks and government

IMPACT:

- \$1.4 billion in total costs
- \$575 million settlement with FTC, CFPB, and states
- \$425 million consumer restitution fund
- CEO, CIO, and CSO resigned
- Congressional hearings and intense regulatory scrutiny
- Credit monitoring for all affected consumers
- Massive reputational damage to core business (credit reporting/trustworthiness)

As an CS Analyst, you are tasked with the following:

1. Identify the Weakest Function

- a. Which CSF function failed the most and allowed the breach to happen?
- b. Write the function name and explain why.
- c. List three specific failures inside that function

2. Governance Analysis

- a. Explain how risk was not properly prioritized.
- b. Who should have been held accountable?
- c. How did oversight fail?
- d. What would have been different if leadership handled cybersecurity correctly?

3. Preventative Controls

- a. For each situation, explain what could have existed to prevent or reduce damage
 - i. Patch not installed
 - ii. Systems not being discovered during scan
 - iii. Credentials stored in plain text
 - iv. Monitoring system not functioning
 - v. Data was stolen for months without detection
- b. Now for each one, name the CSF function involved and describe what should have been done differently

4. Breach Timeline Thinking

- a. In a short 3-5 sentence paragraph, explain how the incident grew worse over time. Did the breach occur at one moment in time? Or did multiple failures compound together? Explain your response.

5. Prevention Recommendations

- a. You are the new security advisor, write a short 3-5 sentence paragraph explaining the single most important change that would have prevented this breach.
- b. This shouldn't be a product or tool, but a process/decision change.

6. Final Reflection

- a. Write a short 3-5 sentence paragraph about what this breach taught you about how organizations fail in cybersecurity

Resources:

https://en.wikipedia.org/wiki/2017_Equifax_data_breach

<https://www.huntress.com/threat-library/data-breach/equifax-data-breach>

<https://investor.equifax.com/news-events/press-releases/detail/237/equifax-releases-details-on-cybersecurity-incident>

<https://www.csoonline.com/article/567833/equifax-data-breach-faq-what-happened-who-was-affected-what-was-the-impact.html>

<https://securityaffairs.com/63043/hacking/equifax-data-breach.html>

<https://news.apache.org/foundation/entry/media-alert-the-apache-software>

<https://www.wired.com/story/equifax-breach-no-excuse>

<https://www.ftc.gov/news-events/news/press-releases/2019/07/equifax-pay-575-million-part-settlement-ftc-cfpb-states-related-2017-data-breach>

Official Government Documentation (copy entire link into browser)

chrome-

extension://oemmndcbldboiebfnladdacbfmadadm/https://oversight.house.gov/wp-content/uploads/2018/12/Equifax-Report.pdf

chrome-

extension://oemmndcbldboiebfnladdacbfmadadm/https://www.hsgac.senate.gov/wp-content/uploads/imo/media/doc/FINAL%20Equifax%20Report.pdf